

Enci/ VENTAS

Informe de Seguridad y Hardening

MVP Web Avanzado - UAT / Go-Live Controlado

Documento 15 - Controles defensivos, riesgos residuales y validacion tecnica

Desarrollado por Grupo PLM - Universidad Tecnologica Metropolitana (UTEM)

Lider: Joshua Flores

Integrantes: Falon Berrios, Carolaine Palacios y Eliseo Poblete

Cliente / representante receptor: Max

Version 1.0 - Julio 2026

AMBITO	ESTADO	CRITERIO
Identidad y autenticacion	Implementado	Firebase Auth y validacion backend con Firebase Admin.
Autorizacion por rol	Implementado	Jerarquia admin, supervisor y vendedor aplicada desde backend.
Datos Firestore	Controlado	Acceso directo desde cliente denegado; operaciones mediante API.
CSV y entrada de datos	Hardening aplicado	Limites, validacion UTF-8, columnas permitidas, duplicados y formula injection.
RAG IA	Parcialmente entregado	Controles propios de endpoint, key solo backend y limites de uso.

Naturaleza del informe

Este documento formaliza el estado de seguridad defensiva del MVP Enci/ Ventas. No reemplaza una auditoria externa certificada ni una prueba de penetracion productiva. Su alcance es documentar los controles incorporados, su evidencia tecnica, las validaciones realizadas y los riesgos residuales aceptables para cierre de Development y preparacion UAT.

Tabla de Contenidos

1. Proposito y alcance
2. Resumen ejecutivo de seguridad
3. Modelo de seguridad aplicado
4. Controles implementados
5. Matriz de hardening
6. Seguridad por rol y propiedad de datos
7. Controles sobre datos, CSV y payload
8. Seguridad RAG y componentes parcialmente entregados
9. Casos de abuso y validacion defensiva
10. Hallazgos mitigados
11. Riesgos residuales y recomendaciones
12. Checklist UAT / Go-Live
13. Criterio de aceptacion del informe

1. Proposito y alcance

El presente informe consolida el estado de seguridad y hardening del sistema Enci/ Ventas desarrollado por el Grupo PLM de la UTEM. Su objetivo es entregar una vision formal, verificable y operativa de los controles defensivos aplicados al MVP web avanzado, junto con las condiciones que deben ser revisadas antes de su salida controlada a UAT o produccion.

El sistema analizado corresponde a una aplicacion comercial tipo MiniCRM, compuesta por frontend React/Vite, backend FastAPI, autenticacion Firebase, persistencia en Cloud Firestore, documentacion Swagger controlada, modulo RAG con DeepSeek en estado parcial y app movil Flutter nativa Android parcialmente realizada fuera del monorepo.

Criterio rector

La seguridad efectiva del MVP no se basa en ocultar botones en la interfaz, sino en validar identidad, rol, estado de usuario, propiedad del recurso y configuracion de ambiente desde el backend antes de ejecutar operaciones de negocio.

1.1 Alcance incluido

- Autenticacion mediante Firebase Auth y uso de ID Token JWT en requests protegidos.
- Validacion backend con Firebase Admin SDK antes de autorizar operaciones.
- Jerarquia de roles: admin, supervisor y vendedor.
- Bloqueo de usuario sin acceso, inactivo o sin plataforma habilitada.
- Restriccion de propiedad para datos comerciales asociados a vendedores.
- Reglas Firestore deny-all para impedir lectura y escritura directa desde cliente.
- CORS restrictivo, rate limit, limite de payload y proteccion de endpoints de documentacion.
- Validaciones defensivas en importacion CSV y modelos Pydantic.
- Controles particulares del modulo RAG: limite de pregunta, limite de consultas, validacion documental y API key solo backend.
- Riesgos residuales propios de MVP, UAT y dependencias externas.

1.2 Alcance no incluido

- No constituye certificacion ISO 27001, SOC 2, PCI DSS ni auditoria legal externa.
- No reemplaza pentest profesional ejecutado sobre ambiente productivo real.
- No cubre hardening de infraestructura final si el cliente modifica dominios, credenciales o proveedor de hosting despues de la entrega.
- No garantiza SLA de terceros como Firebase, Google Cloud, Vercel, Render, DeepSeek u otros servicios externos.
- No incluye mantenimiento post-entrega ni correcciones futuras fuera del alcance aceptado.

2. Resumen ejecutivo de seguridad

El estado general de seguridad es apto para cierre de Development del MVP web, condicionado a validacion UAT con usuarios reales, credenciales finales y dominios autorizados. La arquitectura implementa controles de

defensa en capas: identidad centralizada, autorizacion backend, validacion de propiedad, restriccion de Firestore, controles de entrada y reduccion de superficie publica.

Dominio	Estado	Resultado ejecutivo
Identidad	Implementado	Firebase Auth emite ID Token; backend valida token antes de exponer datos.
Sesion	Implementado	Sesion gestionada desde frontend y token aplicado como Bearer; ante 401 se fuerza salida.
Roles	Implementado	Autorizacion por require_role: vendedor, supervisor y admin.
Propiedad de datos	Implementado	Vendedor opera solo clientes, interacciones, oportunidades y propuestas propias.
Firestore	Controlado	Reglas deny-all para acceso directo desde cliente; API es la via de negocio.
CSV	Hardening aplicado	Limite de 1 MB, maximo 1000 filas, encoding UTF-8, columnas permitidas y duplicados.
Swagger/OpenAPI	Controlado	Consola de pruebas disponible fuera de produccion; bloqueada en production.
RAG	Parcial controlado	Endpoint protegido, key solo backend, rate limit por uid y validacion de documentos.
UAT/Go-live	Pendiente cliente	Depende de ambiente final, dominios, credenciales, usuarios reales y smoke test.

Decision tecnica

El MVP puede considerarse cerrado para Development en materia de hardening base. La salida productiva debe quedar condicionada a checklist UAT, revision de credenciales reales, dominios autorizados, reglas desplegadas y pruebas manuales con usuarios representativos.

3. Modelo de seguridad aplicado

El modelo de seguridad opera bajo una premisa de confianza minima: el frontend organiza la experiencia visual, pero no decide permisos finales. Todo endpoint protegido debe recibir un token valido, obtener el usuario desde Firestore, verificar rol, confirmar estado activo y ejecutar validaciones de propiedad antes de acceder o modificar datos.

3.1 Flujo de autenticacion y autorizacion

- 1 El usuario inicia sesion con Google mediante Firebase Auth.
- 2 Firebase entrega un ID Token JWT al frontend.
- 3 El frontend envia cada request protegido con Authorization: Bearer .
- 4 FastAPI recibe el request y delega la verificacion del token en Firebase Admin SDK.
- 5 El backend consulta la coleccion users en Firestore para obtener rol, estado activo y permisos de plataforma.
- 6 El backend aplica require_role y las validaciones especificas del recurso.
- 7 La operacion de negocio se ejecuta solo si las validaciones anteriores son satisfactorias.

3.2 Principios defensivos

Principio	Aplicacion en Enci/ Ventas
Autorizacion backend	El frontend puede ocultar vistas, pero el permiso real se valida en FastAPI.
Menor privilegio	Vendedor accede a su ambito; supervisor accede a consolidado; admin gestiona configuracion y usuarios.
Negacion por defecto	Usuario sin registro queda como sin_acceso; Firestore directo queda deny-all.
Validacion de entrada	Modelos Pydantic rechazan campos extra, formatos invalidos y valores peligrosos.
Auditoria operativa	Cambios criticos registran eventos para trazabilidad tecnica.

Principio	Aplicacion en Enci/ Ventas
Separacion de secretos	Llaves sensibles como DeepSeek y Firebase Admin quedan solo en backend o entorno seguro.

4. Controles implementados

Esta seccion detalla los controles aplicados sobre identidad, sesion, API, datos, documentacion y componentes complementarios. Cada control se interpreta como parte de una defensa acumulativa: ninguno por separado elimina todos los riesgos, pero en conjunto reduce la superficie de ataque del MVP.

Categoria	Control	Criterio de aceptacion
Identidad	Google SSO mediante Firebase Auth.	Todo acceso protegido requiere token Firebase valido.
Sesion	Token usado como Bearer y no como credencial persistente de negocio.	Ante token invalido o expirado, la API responde 401 y el frontend fuerza login.
Backend	Firebase Admin SDK verifica token.	Sin token valido no se ejecutan endpoints protegidos.
Roles	require_role(vendedor/supervisor/admin).	El rol se decide en backend desde Firestore.
Usuarios	Usuario sin_acceso, inactivo o sin plataforma queda bloqueado.	Debe responder 403 aunque tenga token valido.
Propiedad	Vendedor restringido a registros propios.	Manipulacion de IDs ajenos debe responder 403/404 segun caso.
Firestore	Reglas cliente deny-all.	Cliente web o movil no debe escribir directo en Firestore.
CORS	Origenes permitidos configurados y wildcard bloqueado en produccion.	Produccion no acepta CORS abierto.
Rate limit	Control transversal por IP y control especifico RAG por uid.	Rafagas basicas quedan mitigadas.
Payload	Limite global de request y limites especificos CSV/RAG.	Requests sobredimensionados se rechazan antes de procesar.
OpenAPI	Docs bloqueadas en production.	/docs y /openapi.json no quedan como superficie publica productiva.
Headers	CSP, X-Frame-Options, Referrer-Policy y otros headers defensivos.	Reducir riesgo de configuraciones inseguras del navegador.

5. Matriz de hardening

La matriz siguiente resume el estado de hardening por componente. Se distinguen controles implementados, controles condicionados a ambiente y recomendaciones futuras fuera del cierre base.

ID	Componente	Control aplicado	Estado	Observacion
HD-01	Backend FastAPI	Validacion token Firebase y rol por endpoint.	Implementado	Control obligatorio en rutas protegidas.
HD-02	Usuarios	Bloqueo de usuario inactivo y usuario sin_acceso.	Implementado	Requiere datos correctos en Firestore.
HD-03	Cientes CRM	Vendedor limitado a vendedorUid u ownerUid propio.	Implementado	Mitiga BOLA sobre clientes.
HD-04	Interacciones	Creacion y listado bajo contexto del vendedor.	Implementado	Asociacion controlada por cliente visible.
HD-05	Oportunidades	Cambio de etapa solo sobre oportunidad visible.	Implementado	Evita manipulacion cruzada.
HD-06	Propuestas	Monto total calculado server-side.	Implementado	Evita depender del calculo frontend.
HD-07	CSV	Validacion atomica de duplicados y columnas.	Implementado	Si hay errores, no se importan filas.
HD-08	Firestore	Reglas deny-all versionadas.	Implementado	Debe confirmarse despliegue en Firebase real.

ID	Componente	Control aplicado	Estado	Observacion
HD-09	Swagger	Bloqueo en production.	Implementado	Disponible solo para ambientes controlados.
HD-10	RAG	Rate limit, key backend, validacion archivo, limite pregunta.	Parcial	No reemplaza auditoria especifica de IA.
HD-11	Flutter	Login Firebase y consumo API previsto.	Parcial	App fuera de monorepo; seguridad final requiere revision del APK.
HD-12	E2E	Plan documentado.	Pendiente/Fase 2	Requiere estrategia estable de login.

6. Seguridad por rol y propiedad de datos

La autorizacion por rol es central para el modelo de seguridad. El sistema diferencia permisos segun vendedor, supervisor y admin. La existencia visual de una pantalla no implica permiso; el backend mantiene la decision final.

6.1 Roles operativos

Rol	Permisos principales	Restricciones
Vendedor	Opera clientes, interacciones, oportunidades, propuestas y dashboard propio.	No debe acceder ni modificar informacion comercial de otros vendedores.
Supervisor	Consulta informacion consolidada y funciones de supervision.	No reemplaza al admin en cambios sensibles si el endpoint exige admin.
Admin	Gestiona usuarios, roles, estados, importacion CSV y configuraciones operativas.	Debe utilizarse solo con cuentas autorizadas y trazabilidad.
Sin acceso	Sin permisos operativos.	Debe quedar bloqueado en login, /me y endpoints protegidos.

6.2 Propiedad de recursos

El vendedor queda asociado a registros comerciales mediante identificadores como vendedorUid u ownerUid. Cuando intenta acceder a un cliente u operacion ajena, el backend debe rechazar la accion aunque el frontend haya sido manipulado, la URL se haya escrito manualmente o el ID haya sido obtenido por otro medio.

Caso defensivo	Comportamiento esperado
Vendedor abre cliente ajeno por URL	Respuesta 403 o no exposicion del recurso.
Vendedor intenta editar ownerUid/vendedorUid	Backend ignora o remueve campos no autorizados.
Vendedor intenta crear propuesta sobre oportunidad ajena	Backend rechaza por propiedad.
Supervisor consulta dashboard consolidado	Permitido bajo rol supervisor/admin.
Admin cambia rol o estado de usuario	Permitido, con trazabilidad operativa.

7. Controles sobre datos, CSV y payload

El sistema incorpora validaciones especificas para impedir corrupcion logica de datos, cargas sobredimensionadas, campos no autorizados y vectores basicos de formula injection asociados a hojas de calculo.

7.1 Importacion CSV

Control	Detalle aplicado
Tamano maximo	1 MB por archivo CSV.

Control	Detalle aplicado
Filas maximas	1000 filas por archivo.
Encoding	UTF-8 / UTF-8 con BOM.
Columnas permitidas	nombre, empresa, email, telefono, rubro, region, estado, vendedorUid, ownerUid.
Duplicados internos	Correo repetido dentro del archivo genera error.
Duplicados existentes	Correo ya presente en CRM genera error.
Atomicidad operativa	Si existen errores de validacion, no se importan filas.
Formula injection	Valores iniciados con =, +, - o @ se rechazan en campos de texto controlados.

7.2 Modelos y validacion server-side

Los modelos de entrada usan validaciones Pydantic, limites de longitud, tipos enumerados, campos extra prohibidos y normalizaciones controladas. Esto reduce el riesgo de mass assignment, inconsistencias de estado y datos inesperados.

- Ejemplos de controles esperados:
- ConfigDict(extra="forbid") en modelos de entrada.
 - Email validado como EmailStr.
 - Telefono normalizado para formato movil chileno.
 - Etapas y estados acotados a valores canonicos.
 - Descuento y probabilidad con rangos definidos.

8. Seguridad RAG y componentes parcialmente entregados

El modulo IA RAG debe interpretarse como componente parcialmente entregado. Su seguridad se basa en restringir acceso por rol, limitar el tamano de entrada, controlar frecuencia por usuario, mantener la API key fuera del frontend y registrar fuentes cuando existe contexto documental.

Elemento RAG	Control documentado
Acceso	POST /rag/chat exige rol vendedor o superior. Carga, reindexacion y listado documental quedan para admin.
Pregunta	Texto sanitizado y limitado a 1000 caracteres.
Frecuencia	Rate limit por uid, con valor operativo de 30 consultas por minuto.
Proveedor	DeepSeek configurado solo desde backend mediante DEEPSEEK_API_KEY.
Archivos	Carga limitada a PDF, DOCX y TXT UTF-8; validacion de extension y contenido.
Tamano	Carga documental limitada a 20 MB.
Indice	Chunks y embeddings en Chroma local persistido.
Sin contexto	Respuesta local sin invocar proveedor externo cuando no hay contexto suficiente.

8.1 Limites de aceptacion RAG

Alcance parcial

La aceptacion del RAG no implica obligacion de reentrenar, optimizar prompts, evaluar calidad avanzada, cambiar proveedor, migrar a Vertex/Gemini, cargar corpus masivo ni garantizar SLA de proveedor externo.

8.2 App Flutter

La aplicacion nativa Flutter Android se considera componente parcialmente realizado y desarrollado fuera del monorepo GitHub. Su ausencia en el repositorio principal no debe interpretarse como inexistencia del entregable. Para seguridad final del canal movil, se recomienda revisar APK, configuracion Firebase, dominios autorizados, almacenamiento local y manejo de tokens antes de produccion real.

9. Casos de abuso y validacion defensiva

Los casos de abuso permiten validar que el sistema resiste manipulaciones previsibles de usuario autenticado, errores de configuracion comun y entrada de datos malformada.

ID	Caso de abuso	Resultado esperado	Severidad
AB-01	Acceso sin token a endpoint protegido.	401 Unauthorized.	Critica
AB-02	Token invalido o expirado.	401 y cierre de sesion en frontend.	Critica
AB-03	Usuario inactivo con token valido.	403 Forbidden.	Critica
AB-04	Vendedor accede cliente ajeno por ID.	403 o no exposicion del recurso.	Critica
AB-05	Vendedor intenta modificar vendedorUid.	Campo ignorado o rechazado.	Alta
AB-06	CSV con columnas no soportadas.	400 Bad Request.	Media
AB-07	CSV con email duplicado.	Error de validacion y cero escrituras.	Media
AB-08	CSV mayor a 1 MB.	413 Content Too Large.	Media
AB-09	Frontend Vercel no autorizado en CORS.	Bloqueo CORS hasta configurar origen.	Alta
AB-10	Docs publicas en production.	404 Not Found.	Alta
AB-11	RAG sin API key DeepSeek.	Readiness not_ready / respuesta controlada.	Media

10. Hallazgos mitigados

Durante el endurecimiento del MVP se identificaron brechas tecnicas asociadas a control de propiedad, duplicados, trazabilidad, manejo de errores y configuracion de reglas. Los hallazgos listados se consideran mitigados o documentados para tratamiento posterior.

Hallazgo	Riesgo	Mitigacion aplicada	Estado
Firestore sin reglas cerradas versionadas	Acceso directo accidental desde cliente.	Reglas deny-all en firestore.rules.	Mitigado
Propuesta vinculable a oportunidad no visible	Relacion comercial cruzada.	Validacion de oportunidad visible antes de crear propuesta.	Mitigado
Propuestas sin oportunidad	Trazabilidad comercial incompleta.	oportunidadId obligatorio.	Mitigado
Duplicados CSV	Corrupcion logica del CRM.	Validacion interna y contra CRM antes de escribir.	Mitigado
Cambio de estado sin manejo de error UI	Desincronizacion visual.	Try/catch, estados de guardado y mensajes.	Mitigado
Dependencia del frontend para ocultar roles	Acceso por URL manipulada.	require_role backend y ProtectedRoute visual.	Mitigado
Consultas en memoria	Riesgo de rendimiento al escalar.	Aceptado para MVP; migrar a queries/indexes en fase productiva.	Residual

11. Riesgos residuales y recomendaciones

Los riesgos residuales no invalidan el cierre de Development, pero deben quedar visibles para la salida productiva. Su tratamiento depende de decisiones de infraestructura, volumen real, usuarios finales,

disponibilidad de credenciales y definicion de soporte posterior.

Riesgo residual	Impacto	Recomendacion
Credenciales Firebase reales no validadas en entorno final.	Login o API bloqueados en UAT.	Validar proyecto Firebase, dominios y service account antes de entregar acceso a usuarios.
E2E automatizado pendiente.	Regresiones visuales no detectadas automaticamente.	Definir login mockeado o proyecto Firebase de pruebas.
Consultas Firestore con filtros en memoria.	Rendimiento limitado con alto volumen.	Migrar a queries con indices y paginacion server-side antes de produccion masiva.
RAG parcial y proveedor externo.	Respuestas limitadas o indisponibilidad por proveedor.	Documentar alcance, consumo, cuotas, calidad esperada y fallback.
Flutter fuera del monorepo.	Menor trazabilidad de revision tecnica.	Conservar APK, evidencia, configuracion y revision de manejo de tokens.
Secretos administrados por entorno.	Exposicion si se cargan por error en frontend o repo.	Mantener .env fuera de Git y rotar secretos ante sospecha.
Sin pentest externo.	Riesgos no descubiertos por pruebas internas.	Ejecutar pentest si el sistema opera con datos reales sensibles o alta exposicion.

12. Checklist UAT / Go-Live

Antes de abrir el sistema a usuarios reales, se debe ejecutar una validacion operativa de seguridad. Esta lista debe quedar firmada o al menos evidenciada mediante captura, log o acta tecnica.

N.	Control	Evidencia minima	Estado
1	GET /health responde status ok.	Captura o log curl.	Pendiente UAT
2	GET /readiness responde ready.	Captura JSON sin checks fail.	Pendiente UAT
3	Firebase Auth contiene dominios finales autorizados.	Captura consola Firebase.	Pendiente cliente
4	Backend CORS contiene dominios finales y no usa wildcard.	Variables de entorno revisadas.	Pendiente infra
5	Firestore rules deny-all desplegadas.	Captura o comando firebase deploy/status.	Pendiente infra
6	Usuario vendedor solo ve clientes propios.	Prueba con usuario real.	Pendiente UAT
7	Usuario supervisor ve consolidado.	Prueba con usuario real.	Pendiente UAT
8	Admin puede gestionar usuarios y CSV.	Prueba controlada.	Pendiente UAT
9	Usuario inactivo queda bloqueado.	Prueba con cuenta marcada activo=false.	Pendiente UAT
10	/docs y /openapi.json no expuestos en production.	Validacion HTTP 404.	Pendiente go-live
11	RAG responde con fuente o sin contexto controlado.	Consulta de prueba.	Pendiente UAT
12	No existen secretos en variables VITE_* ni frontend.	Revision de build/env.	Pendiente final

13. Criterio de aceptacion del informe

El informe se considera aceptado cuando el cliente reconoce que el MVP web incorpora controles razonables de seguridad defensiva para cierre de Development, que la autorizacion reside en backend, que Firestore no debe exponerse al cliente directo, que RAG y Flutter son componentes adicionales parciales y que la salida productiva queda condicionada a UAT, ambiente final, credenciales, dominios y validaciones operativas.

Declaracion final

El estado de seguridad del MVP Enci/ Ventas es apto para continuidad hacia UAT controlado. Los riesgos residuales identificados no constituyen incumplimiento del desarrollo base siempre que permanezcan documentados, aceptados y sujetos a validacion antes de produccion real.

13.1 Fuentes tecnicas relevantes

Fuente	Uso en este informe
Backend/app/main.py	Middleware, CORS, rate limit, headers, rutas base y control de documentacion.
Backend/app/core/auth.py	Validacion de token, acceso por plataforma, roles y bloqueo de usuarios.
Backend/app/core/config.py	Variables de entorno, CORS, Firebase y configuracion RAG.
Backend/app/services/clientes.py	Validaciones de clientes, CSV, duplicados, limites y auditoria.
Backend/app/models/*.py	Contratos Pydantic, rangos, enumeraciones y rechazo de campos extra.
firestore.rules	Regla deny-all para acceso directo desde cliente.
docs/qa/epic-03-auditoria.md	Auditoria QA, bugs corregidos, brechas de seguridad y evidencias.
docs/qa/epic-04-hardening.md	Hardening, navegacion por rol, dashboards y plan E2E.
docs/qa/epic-05-uat-go-live.md	Readiness, checklist UAT, smoke test, rollback y riesgos residuales.

Documento preparado por Grupo PLM - Universidad Tecnologica Metropolitana (UTEM).
Lider: Joshua Flores. Integrantes: Falon Berrios, Caroline Palacios y Eliseo Poblete.